

Uncoverable by Design: The Ceiling that Seven Years of MITRE ATT&CK Mitigation Gaps Place on Autonomous Cyber Defense

Anonymous Author(s)
Anonymized for double-blind review

Abstract—Autonomous defenders, from control-selection optimisers to LLM-driven security agents, increasingly plan from MITRE ATT&CK, whose *mitigates* relationships say which controls counter which techniques. We ask what such an agent can *guarantee* when that mapping has gaps. Across every comparable Enterprise release from v5.2 (2019-07) to v19.2 (2026-08), ransomware kill-chain techniques with no mitigation rose from 61 to 114 (+87%; +21% if sub-techniques inherit their parent’s mitigations). Gaps rarely close: only 13 ever gained a mitigation, and an estimated 88% remain open five years after they appear. They are real routes: 82 of the 85 entities ATT&CK documents as encrypting data for impact are documented using an uncovered technique. Against an adaptive adversary the gaps impose a policy-independent *ceiling*: with interval-uncertain base rates and control effectiveness, no portfolio of ATT&CK mitigations can be certified to keep the worst-case probability of a clinical-service outage in our hospital-ransomware model below 23.0% (14.7% in 2019-07). The level depends on assumptions, but its 1.56-fold rise provably does not depend on the base rate. A reference autonomous defender shows what this means for agents: only 3 of the 28 mitigations it deploys change the certified risk, and the full portfolio certifies just 1.95 times less risk than deploying nothing. Mapping a mitigation to 6 specific techniques (found by an exact minimal repair) would make a 10% certificate attainable. The longitudinal series, the ceiling and the repair are, to our knowledge, new; the arguments are elementary.

Index Terms—autonomous cyber defense, MITRE ATT&CK, threat-informed defense, certification, ransomware, measurement

1. Introduction

Cyber operations are being automated on both sides. Offensive agents already plan and execute intrusion steps [5], and autonomous defenders are trained in simulated networks [6] or built on language models that reason over threat intelligence. Whatever their design, defensive agents that select controls need a model of which control counters which technique, and the de facto source is ATT&CK. This paper measures a property of that source that no agent can learn its way around: techniques that ATT&CK maps to no mitigation at all. Against an attacker that adapts to the defense, they set a *ceiling* on what any defender choosing from ATT&CK’s mitigations can certify, whatever its policy.

ATT&CK [1] catalogues adversary behaviour as tactics and techniques and links each technique to the mitigations that counter it. Those links are the defensive half of the model: coverage heatmaps, control-gap assessments and automated control-selection tools all consume them [2], [3]. A technique with no mitigation cannot be covered by any portfolio of mapped mitigations, however large, so every tool that reasons only from the mapping inherits it as a permanent gap.

This paper asks four questions of that defensive half, using real ATT&CK data across releases. **(Q1)** How many ransomware kill-chain techniques have no mitigation, do individual gaps ever close, and does documented ransomware use them? **(Q2)** What lower bound on certifiable worst-case residual risk do those gaps force on *any* defense built from ATT&CK mitigations? **(Q3)** What is the smallest set of techniques that would need a mitigation for a given guarantee to become attainable, and which are they? **(Q4)** Which of these answers depend on counting conventions and model parameters, and which do not? **(Q5)** What does the ceiling mean for an autonomous defender that plans from ATT&CK?

Contributions. (i) A longitudinal measurement of mitigation coverage over 15 comparable Enterprise releases (2019-07–2026-08), handling the mitigation restructure, the arrival of sub-techniques, the v19 split of Defense Evasion, and placeholder mitigations explicitly, under two sub-technique conventions, with a technique-level survival analysis of how long gaps persist and a measurement of how often ATT&CK’s own procedure examples for ransomware use them. (ii) A distribution-free certification floor per release (Proposition 1) and a factorisation showing that its growth across releases is free of the base rate (Proposition 2). (iii) An exact minimal repair, justified by a structural result that partial repair of a stage is worthless (Proposition 3), with the resulting technique list. (iv) Sensitivity of every headline to conventions and parameters. (v) A reference autonomous defender run on every release, showing that certified progress against an adaptive adversary is sparse and bounded, and a per-release ceiling that can serve as a scoring target for defender agents. Data, code and tables will be released with hash-pinned provenance.

2. Background and related work

ATT&CK’s design is documented by its authors [1]. Two surveys systematise the research that uses it [2], [3]; they track how the framework has grown and how it is

applied, but do not measure the techniques it leaves without a mitigation over time. Closest to our work, Rahman and Williams [4] study how far NIST SP 800-53 controls mitigate 188 ATT&CK techniques through the Center for Threat-Informed Defense’s control mapping, in one snapshot; we instead use ATT&CK’s own mitigation objects, follow them across seven years of releases, and turn the gaps into a bound and a repair problem. Vendor “ATT&CK coverage” reports concern *detection* coverage of a product, not the knowledge base’s own mitigation mapping. Autonomous-defense research trains and evaluates agents in simulated environments such as CybORG [6], and LLM agents now automate offensive steps [5]; such work scores agents empirically, whereas we bound what any agent planning from ATT&CK can certify. Our floor uses a sharp distribution-free bound on the probability that at least k of n dependent events occur (a Fréchet-type bound [8]; statement and proof in Appendix A). Our search for prior work (arXiv and web search for ATT&CK together with mitigation coverage, mitigation gaps, unmitigated techniques and control mapping, September 2026) found no longitudinal measurement of unmitigated techniques; this is an absence of evidence, not proof of novelty.

3. Data and definitions

Releases. We take the latest patch of every major Enterprise release, 19 in all, from MITRE’s official STIX repository; raw bundles are hash-verified and compact extracts are released. A release is *comparable* if its mitigations use the generalised M#### identifiers, every kill-chain stage is populated, and T1486 (Data Encrypted for Impact) is present. Releases v1–v4 fail the first test — their mitigations were technique-specific objects, one per technique — so the series begins at v5.2.

Kill chain and coverage. The kill chain is the post-compromise ransomware tactics from Initial Access to Impact, 12 stages in all. A *real mitigation* is any active mitigation except the placeholders M1055 *Do Not Mitigate* and M1056 *Pre-compromise*, which record that no preventive control applies. A kill-chain technique is *uncovered* if it has no real mitigation. By default each technique, including each sub-technique, is judged by its own mapping; the *inheritance* convention instead lets an unmapped sub-technique inherit its parent’s mitigations, as a coverage tool that rolls sub-techniques up to parents would.

Documented usage. ATT&CK records procedure examples as *uses* relationships from software, groups and campaigns to techniques. We call an entity *ransomware* if it is documented as using T1486, and for each release count the ransomware entities with documented use of an uncovered kill-chain technique and the share of their kill-chain technique uses that fall on uncovered techniques.

Gap persistence. Following each technique across comparable releases, a *gap spell* starts in the first release in which the technique is on the kill chain without a mitigation and ends in the first later release in which it has one; it is censored when the technique leaves the kill chain (deprecated,

revoked, or restructured into sub-techniques) or at the latest release. We estimate the share of gaps still open t years after they are first observed with the Kaplan–Meier estimator. Spells already open in v5.2 may predate the series; we report the estimate with and without them.

Structural breaks. Sub-techniques arrive in v7, so technique counts jump; we report parent-technique counts alongside. ATT&CK v19 splits Defense Evasion into Stealth and Defense Impairment; a crosswalk maps both to one stage so the kill-chain model is constant across releases, and we report the split as a sensitivity.

4. The certification floor

Following distribution-free certificate models of control adequacy, each technique t succeeds per attempt with base rate b , and each deployed mitigation m that covers t multiplies that by $1 - e_m$. Both are interval-uncertain: $b \in [0.5, 0.9]$, and each e_m has lower end 0.20, except the evidence-tightened MFA control M1032 with lower end 0.85. A certificate must hold over the whole uncertainty set, so it is decided at the worst corner ($b = 0.9$, every e_m at its lower end). An *adaptive* adversary best-responds to the defense by using, at each stage, the technique with the largest residual; clinical reachability is the product of the 12 stage maxima, and the probability that at least k of four clinical services suffer sustained outage is bounded by the sharp k -of- n bound at marginals proportional to it.

Proposition 1 (Floor). *Over all portfolios of real ATT&CK mitigations, adaptive reachability is minimised by deploying every mitigation, and every stage containing an uncovered technique has factor exactly b .*

Proof. Deploying m multiplies each residual it touches by $1 - e_m \leq 1$ and leaves the rest unchanged, so residuals, stage maxima and their product are non-increasing in the portfolio; the full portfolio is a minimiser. An uncovered technique has residual b under every portfolio, and every residual is at most b , so its stage maximum is b . $\square$

Hence a certificate “ $\Pr(\geq k \text{ services down}) \leq \varepsilon$ ” is attainable with ATT&CK mitigations only if the floor is at most ε . The floor’s level is driven by b , but its change across releases is not:

Proposition 2 (Base-rate factorisation). *For fixed effectiveness values, the floor reachability of a release is $F(b) = b^n C$, where n is the number of stages and C depends only on the release’s coverage and the effectiveness values. Hence the ratio of the floors of two releases with the same stages does not depend on b , and neither does the ratio of their k -of- n floors while both are below one.*

Proof. Each residual is b times a product of $(1 - e_m)$ factors, so each stage maximum is b times the maximum of those products, and F is b^n times the product of the latter. The sharp k -of- n bound is a minimum of linear functions of the marginals and 1, so it is positively homogeneous in F until it reaches one. $\square$

5. Minimal coverage repair

Suppose a set R of uncovered techniques each gains one mitigation of worst-corner effectiveness e_{new} . We seek the smallest $|R|$ making the floor at most ε . Let U_s be the uncovered techniques of stage s .

Proposition 3 (Whole-stage repair). *For any feasible R , the set $R' = \bigcup \{U_s : U_s \subseteq R\}$ is feasible, has $|R'| \leq |R|$, and yields the same floor. Hence an optimal repair is a union of whole stage gap sets.*

Proof. By Proposition 1, a stage keeps factor b while any member of U_s is unrepaired, so only stages with $U_s \subseteq R$ change. $R' \subseteq R$ completes exactly those stages, and the techniques in $R \setminus R'$ lie in stages that stay at b ; so the floor is unchanged. $\square$

With 12 stages, enumerating stage subsets and costing each union of gap sets — counting a technique shared by several tactics once — solves the problem exactly. We verify the procedure against brute force over every subset of uncovered techniques on instances with shared techniques.

6. Results

Coverage is not keeping pace. Figure 1 (left) and Table 2: between v5.2 and v19.2 the kill chain grew by 146% (244 to 601 techniques) while real mitigations grew only from 39 to 42. Uncovered techniques rose from 61 to 114 (+87%). As a share, the gap fell when sub-techniques arrived (25.6% to 19.6%), bottomed at 17.4% in v15.1, and has risen since to 19.0%; among parent techniques, uncovered ones rose from 40 in v7 to 48. Thin coverage — techniques with exactly one mitigation — doubled, from 66 to 135. The gap is concentrated (Table 3): 71% of discovery techniques (35 of 49) and 43 defense-evasion techniques have no mitigation, and 10 of 12 kill-chain stages contain at least one uncovered technique (8 in v5.2). Much of the growth is sub-techniques whose parent is mapped: with inheritance, uncovered techniques rose from 61 to 74 (+21%) and 9 stages contain a gap. The direction holds under both conventions; the size does not.

The floor has risen. Figure 1 (right): no portfolio can be certified to keep the worst-case probability that at least one of the four clinical services suffers sustained outage below 14.7% with v5.2 mitigations and 23.0% with v19.2 mitigations (5.1% for all four services at once). The hospital model is not what drives this: the floor on reaching T1486 itself, which uses no impact model, rose from 9.3% to 14.5% (1.56-fold). With inheritance the latest floor is 18.4% (a 1.25-fold rise instead of 1.56-fold). The floor is set stage by stage by a single *binding* technique — the adversary’s best route — so it moves only when one mapping decision changes a binding technique; across the comparable releases that happened 6 times (Table 5). The sharpest pair: in v16.1 the floor fell from 23.0% to 18.4% because Data Destruction (T1485), which bound the impact stage, gained further mitigations; in v17.1 a single newly added technique

with no mitigation, Hypervisor CLI (T1059.012), opened a gap in execution and returned the floor to 23.0%. A single unmitigated technique was enough to cancel that improvement. If every gap were closed with a mitigation as strong as the existing ones, the floor would fall to 2.5% — a 9.3-fold reduction.

Gaps rarely close. Table 2 counts gaps release by release; following individual techniques shows that they almost never close (Figure 3, left). Across 14 release transitions, 13 uncovered techniques gained a mitigation, 1 covered technique lost all of its mitigations, and 94 techniques entered the kill chain without a mitigation. None has closed since v15.1, 4 releases ago. Of the 61 techniques uncovered in v5.2, 29 are still uncovered, 5 gained a mitigation and 27 left the kill chain at v7, when techniques were restructured into sub-techniques; of the 95 gap spells that began later, 8 ended with a mitigation. Over all 156 spells, the estimated share still open is 91% after three years and 88% after five (81 spells still followed at five years); 90% excluding spells open at the start of the series and 79% with parent inheritance, where a parent gaining a mitigation closes its sub-techniques’ gaps at once.

Documented ransomware uses the gaps. Figure 3 (right): in v19.2, 82 of the 85 entities documented as using T1486 are also documented using at least one uncovered kill-chain technique, and 28% of their documented kill-chain technique uses fall on uncovered techniques (77 and 23% with inheritance). The exposure has been at least 90% in every release, from 9 of 10 entities in v5.2. It is concentrated where the gaps are (Table 1): 75 of the 76 ransomware entities with documented Discovery use an uncovered Discovery technique, and 63 of 75 do so in Defense Evasion; the most used, File and Directory Discovery (T1083), is documented for 45 of them. Documented use is not proof of a successful attack path, but it shows the adaptive adversary’s routes are ones real ransomware is recorded as taking.

The minimal repair is small for moderate targets. Figure 2: in v19.2, mitigating 6 techniques across 4 stages (Table 6) makes a 10% single-service certificate attainable; a 5% certificate needs 26 techniques across 7 stages; a 1% certificate on all four services needs 36; and a 1% single-service certificate is infeasible even with every gap closed, because the remaining floor is set by thinly covered techniques. With inheritance the 10% and 5% repairs need 3 and 12 techniques. The 10% repair cost was 5 in v5.2, peaked at 9 in v15.1, and is 6 today. At $e_{\text{new}} = 0.2$ and 0.5 the repair costs are identical, because a repaired stage then binds on its weakest existing mapping; a weaker new mitigation ($e_{\text{new}} = 0.1$) raises the 10% repair to 36 techniques and makes the 5% certificate infeasible. The cheapest repair is not the most used: it closes small gap sets in stages that most ransomware is not documented using, and its techniques are documented for at most 2 ransomware entities each (3 for none, Table 6), while Discovery — where the documented use concentrates — stays open because closing it would take 35 techniques. A certificate needs every stage’s route cut somewhere; it does not need the most travelled one cut.

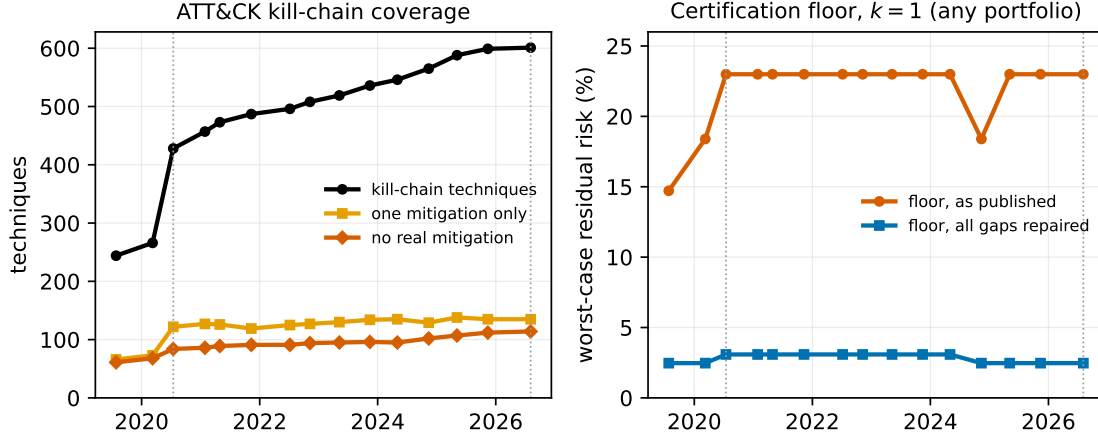


Figure 1. Left: kill-chain techniques, techniques with a single mitigation, and techniques with no real mitigation, per release. Right: the certification floor on the worst-case probability of at least one clinical-service outage ($b = 0.9$), as published and with every gap repaired. Dotted lines: sub-techniques (v7) and the Defense Evasion split (v19).

TABLE 1. THE UNCOVERED KILL-CHAIN TECHNIQUES MOST OFTEN DOCUMENTED FOR RANSOMWARE IN V19.2: THE NUMBER OF ENTITIES DOCUMENTED AS USING BOTH THE TECHNIQUE AND T1486. TACTICS ARE AS PUBLISHED (V19 NAMES STEALTH AND DEFENSE IMPAIRMENT).

Technique	Name	Tactics	Entities
T1083	File and Directory Discovery	discovery	45
T1057	Process Discovery	discovery	35
T1082	System Information Discovery	discovery	35
T1140	Deobfuscate/Decode Files or Information	stealth	30
T1070.004	File Deletion	stealth	28
T1016	System Network Configuration Discovery	discovery	23
T1547.001	Registry Run Keys / Startup Folder	persistence, escalation	22
		privilege-	
T1018	Remote System Discovery	discovery	20
T1680	Local Storage Discovery	discovery	17
T1033	System Owner/User Discovery	discovery	16

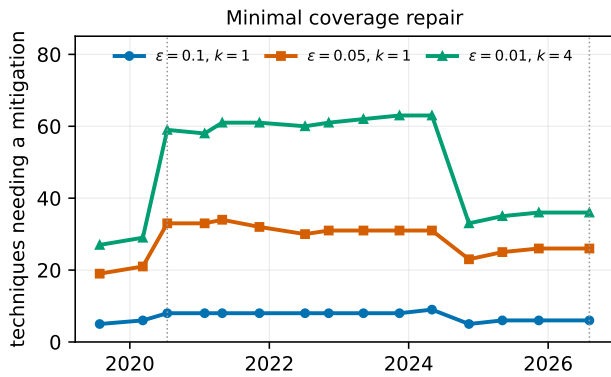


Figure 2. Fewest techniques needing a mitigation for each certificate to become attainable, per release ($\epsilon_{\text{new}} = 0.2$). The target $\epsilon = 0.05, k = 2$ coincides with $\epsilon = 0.10, k = 1$ and is omitted. Dotted lines as in Figure 1.

Levels are assumption-driven; the trend is not. Table 4 varies the upper end of the base-rate interval and the lower

end of mitigation effectiveness. The level of the floor moves by orders of magnitude: it is 1.1% at $b = 0.7$ and 0.02% at $b = 0.5$, and at $b = 0.9$ it is 32.7% or 12.3% as effectiveness is weakened or strengthened. Below $b = 0.9$ no repair is needed even for a 5% certificate; at $b = 0.9$ with stronger effectiveness a 10% certificate needs 1 technique, drawn from the default list (every feasible setting needs only techniques from that list). By Proposition 2, however, the 1.56-fold growth of the floor between v5.2 and v19.2 holds for every b at fixed effectiveness. The robust findings are thus the direction of the gap, the factor by which it has raised the floor, and which techniques bind; the absolute percentages are conditional on the uncertainty set.

Other conventions. Counting the placeholder mitigations as controls — as a literal reading of the mitigates relationships does — reports 111 rather than 114 uncovered techniques in v19.2 and leaves the floor unchanged. Treating v19's Stealth and Defense Impairment as separate stages gives 11 gap stages and a floor of 20.7% (an extra stage multiplies in another factor below one).

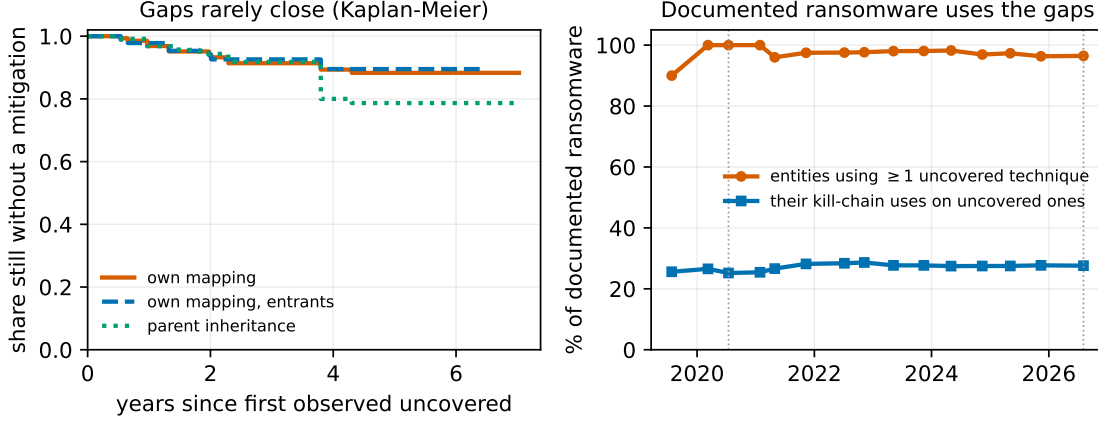


Figure 3. Left: Kaplan–Meier estimate of the share of gaps still open t years after a technique is first observed on the kill chain without a mitigation, over all gap spells, over spells beginning after v5.2, and with parent inheritance; curves end at the longest follow-up. Right: among entities ATT&CK documents as using T1486, the share documented using at least one uncovered kill-chain technique, and the share of their documented kill-chain technique uses that fall on uncovered techniques. Dotted lines as in Figure 1.

TABLE 2. PER RELEASE: KILL-CHAIN TECHNIQUES, REAL MITIGATIONS, UNCOVERED TECHNIQUES (SHARE, %), TECHNIQUES WITH A SINGLE MITIGATION, STAGES CONTAINING AN UNCOVERED TECHNIQUE, THE FLOOR FOR $k=1$ (%), AND THE MINIMAL REPAIR FOR $\varepsilon=0.10$, $k=1$.

Ver.	Date	Tech.	Mit.	Uncovered	One mit.	Gap st.	Floor	Repair
5.2	2019-07	244	39	61 (25.0)	66	8	14.7	5
6.3	2020-03	266	40	68 (25.6)	73	9	18.4	6
7.2	2020-07	428	40	84 (19.6)	122	9	23.0	8
8.2	2021-01	457	40	86 (18.8)	127	9	23.0	8
9.0	2021-04	473	40	89 (18.8)	126	9	23.0	8
10.1	2021-11	487	41	91 (18.7)	119	9	23.0	8
11.3	2022-07	496	41	91 (18.3)	125	9	23.0	8
12.1	2022-11	508	41	94 (18.5)	127	9	23.0	8
13.1	2023-05	519	41	95 (18.3)	130	9	23.0	8
14.1	2023-11	536	41	96 (17.9)	134	9	23.0	8
15.1	2024-05	546	41	95 (17.4)	135	9	23.0	9
16.1	2024-11	565	42	102 (18.1)	129	9	18.4	5
17.1	2025-05	588	42	107 (18.2)	138	10	23.0	6
18.1	2025-11	599	42	112 (18.7)	135	10	23.0	6
19.2	2026-08	601	42	114 (19.0)	135	10	23.0	6

7. Implications for autonomous defenders

Proposition 1 is policy-agnostic: it bounds every portfolio, so it bounds every defender that chooses from ATT&CK’s mitigations, whether an exact optimiser, a reinforcement-learning agent or a language-model agent. To see what that means in practice we run a simple reference defender on every comparable release: starting from nothing, it repeatedly deploys the mitigation that most lowers the adaptive clinical reachability (ties broken by the total residual over all techniques), until the floor is reached.

Certified progress is sparse. In v19.2 the defender deploys 28 of the 42 applicable mitigations before reaching the floor, and only 3 of those steps lower the certified risk (at most 5 in any release). A stage’s factor falls only when *every* technique at the stage’s maximum has been cut, so most single deployments, however sensible, change nothing that

can be certified. For a learning agent rewarded by certified risk this is a sparse-reward problem; for an agent rewarded by coverage counts, it is a reason the two objectives diverge.

The certified value of the whole portfolio is small and has shrunk. Deploying nothing leaves a worst-case outage probability of 44.9%; deploying everything lowers it by a factor of 3.05 in v5.2 and 1.95 in v19.2. By Proposition 2 this factor does not depend on the base rate. Its decline is the gap growth of Section 6 seen from the defender’s side.

A scoring target. Because the ceiling is computable per release, a defender agent’s certified risk can be reported as a multiple of it, separating what the agent failed to do from what ATT&CK does not allow. We will release the per-release ceilings and the minimal repairs for this purpose; a concurrent submission [7] scores a language-model defender against exactly this kind of certificate. On the offensive side, the uncovered techniques are the routes a best-responding

TABLE 3. UNCOVERED/TOTAL TECHNIQUES PER KILL-CHAIN TACTIC, FIRST AND LATEST COMPARABLE RELEASE, AND THE LATEST SHARE (%). THE IMPACT ROW COUNTS EVERY IMPACT TECHNIQUE; THE FLOOR’S IMPACT STAGE USES THE FOUR CLINICAL-IMPACT TECHNIQUES, ALL OF WHICH ARE MITIGATED. DEFENSE EVASION IN v19.2 IS STEALTH $\cup$ DEFENSE IMPAIRMENT.

Tactic	v5.2	v19.2	Share
initial-access	0/11	0/22	0
execution	4/33	1/64	2
persistence	11/59	15/113	13
privilege-escalation	4/28	15/96	16
defense-evasion	23/67	43/204	21
credential-access	3/19	4/67	6
discovery	17/22	35/49	71
lateral-movement	0/17	1/23	4
collection	9/13	13/41	32
command-and-control	0/22	3/45	7
exfiltration	2/9	1/19	5
impact	1/14	6/33	18

TABLE 4. PARAMETER SENSITIVITY IN v19.2: UPPER END OF THE BASE-RATE INTERVAL b , LOWER END OF MITIGATION EFFECTIVENESS e , THE FLOOR FOR $k=1$ (%), AND THE MINIMAL REPAIR FOR A 10% AND A 5% SINGLE-SERVICE CERTIFICATE.

b	e	Floor	Repair 10%	Repair 5%
0.9	0.10	32.74	infeasible	infeasible
0.9	0.20	22.99	6	26
0.9	0.35	12.33	1	10
0.7	0.10	1.60	0	0
0.7	0.20	1.13	0	0
0.7	0.35	0.60	0	0
0.5	0.10	0.03	0	0
0.5	0.20	0.02	0	0
0.5	0.35	0.01	0	0

attacker takes first; we release no attack capability, only counts already implicit in the public knowledge base.

TABLE 5. EVERY CHANGE IN THE FLOOR ACROSS COMPARABLE RELEASES: THE STAGE WHOSE FACTOR CHANGED AND THE TECHNIQUE THAT BINDS IT (THE ADAPTIVE ADVERSARY’S BEST ROUTE) BEFORE AND AFTER. A FACTOR OF 0.900 MEANS THE STAGE CONTAINS A TECHNIQUE WITH NO MITIGATION.

Ver.	Stage	Factor	Binding before	Binding after
6.3	lateral-movement	0.720 → 0.900	T1037 Logon Scripts	T1534 Internal Spearphishing
7.2	initial-access	0.576 → 0.720	T1091 Replication Through Removable Media	T1078.001 Default Accounts
7.2	execution	0.900 → 0.720	T1061 Graphical User Interface	T1059.003 Windows Command Shell
7.2	command-and-control	0.720 → 0.900	T1001 Data Obfuscation	T1568.001 Fast Flux DNS
16.1	impact	0.720 → 0.576	T1485 Data Destruction	T1486 Data Encrypted for Impact
17.1	execution	0.720 → 0.900	T1059.003 Windows Command Shell	T1059.012 Hypervisor CLI

TABLE 6. THE MINIMAL REPAIR IN V19.2 FOR A 10% SINGLE-SERVICE CERTIFICATE: THE TECHNIQUES THAT WOULD NEED A MITIGATION, AND THE NUMBER OF RANSOMWARE ENTITIES DOCUMENTED AS USING EACH.

Technique	Name	Stage	Entities
T1020	Automated Exfiltration	exfiltration	0
T1059.012	Hypervisor CLI	execution	2
T1534	Internal Spearphishing	lateral-movement	0
T1568.001	Fast Flux DNS	command-and-control	1
T1568.003	DNS Calculation	command-and-control	0
T1665	Hide Infrastructure	command-and-control	1

8. Discussion

For the maintainers of ATT&CK, the repair list is a candidate authoring agenda: a handful of mitigation mappings would change what any ATT&CK-driven defense can be certified to achieve under our model, although it is not a list of the most used gaps, whereas the long tail of Discovery techniques — routine enumeration of the environment — is where preventive mitigations are hardest to write and where detection must carry the load. For builders of control-selection and coverage tools, every uncovered technique is a gap inherited by construction; tools should surface it rather than report full coverage, and should state which sub-technique convention they use, since it changes the count substantially. For defenders, the floor is a reason to pair preventive portfolios with detection and response for the uncovered techniques, and the thin-coverage count identifies where a single failed control leaves a technique effectively unmitigated.

9. Limitations

Mapping, not reality. “No mitigation in ATT&CK” measures the knowledge base’s mitigation *mapping*, not the absence of any real-world defense; detections and vendor controls exist for many uncovered techniques, and a technique may lack a mapping because no *preventive* control is appropriate. Coverage counts inherit ATT&CK’s editorial choices, including when behaviours are split into sub-techniques.

Levels are assumption-driven. The floor’s level depends on the base-rate interval, the effectiveness intervals, a stage-based kill-chain model and a synthetic hospital-ransomware impact model; Table 4 shows it can fall below 1%. It is a bound under those assumptions, not a measured incident rate, and we do not validate it against incidents. Only its relative change is free of the base rate.

Required tactics. We assume every kill-chain tactic must be traversed. Requiring fewer tactics removes factors below one from the product, so it can only raise the floor: ours is a lower bound for any subset of required tactics under the same parameters.

Counting conventions. The size of the growth in uncovered techniques depends on whether sub-techniques inherit their parent’s mitigations (+87% versus +21%). Placeholder mitigations and the v19 split are handled by stated rules, with alternatives reported.

Documented usage and persistence. ATT&CK’s procedure examples record what has been publicly reported, so they are biased toward well-studied families and toward techniques that are easy to observe, such as Discovery; absence of a documented use is not evidence of non-use. Using T1486 is a proxy for ransomware and also captures some encrypting wipers. The survival analysis treats a restructure into sub-techniques as censoring, assumes censoring is unrelated to whether a gap would have closed, and has few spells followed for the full period.

Adversary. The adaptive adversary is worst case: it knows the defense and always uses the easiest technique at each stage. Real adversaries are less informed, so the floor bounds what can be *certified*, not what is typically experienced.

Repair. The repair assumes a new mitigation behaves like the existing ones; we report sensitivity to its strength. Writing an effective mitigation for a technique may be infeasible, which the count does not capture.

Artifact and AI use. Per-release extracts with SHA-256 provenance, the analysis code, tests (including exact agreement with an independent implementation of the floor and a brute-force check of the repair), and every table will be released on publication; all numbers in this paper are

generated from those tables. The analysis code and draft text were produced with the assistance of an AI system (Claude); all results are reproduced by automated tests.

References

- [1] B. E. Strom et al. MITRE ATT&CK: Design and Philosophy. MITRE Technical Report, 2018 (revised 2020).
- [2] S. Roy, E. Panaousis, C. Noakes, A. Laszka, S. Panda, and G. Loukas. SoK: The MITRE ATT&CK Framework in Research and Practice. arXiv:2304.07411, 2023.
- [3] B. Al-Sada, A. Sadighian, and G. Oligeri. MITRE ATT&CK: State of the Art and Way Forward. *ACM Computing Surveys*, 2024. arXiv:2308.14016.
- [4] M. R. Rahman and L. Williams. An investigation of security controls and MITRE ATT&CK techniques. arXiv:2211.06500, 2022.
- [5] G. Deng, Y. Liu, V. Mayoral-Vilches, P. Liu, Y. Li, Y. Xu, T. Zhang, Y. Liu, M. Pinzger, and S. Rass. PentestGPT: Evaluating and harnessing large language models for automated penetration testing. In *USENIX Security Symposium*, 2024.
- [6] M. Standen, M. Lucas, D. Bowman, T. J. Richer, J. Kim, and D. Marriott. CybORG: A gym for the development of autonomous cyber agents. arXiv:2108.09118, 2021.
- [7] Anonymous. A certified cyber range for automated defenders: Provable residual-risk scores against an adaptive adversary. Concurrent submission to AIDC 2026.
- [8] L. Rüschendorf. Bounds for distributions with multivariate marginals. In *Stochastic Orders and Decision under Risk*, IMS Lecture Notes, 1991.

Appendix A.

The sharp k -of- n bound

Lemma 1. *Let $X_1, \dots, X_n$ be Bernoulli with marginals $p_1, \dots, p_n$, ordered so that $p_{(1)} \geq \dots \geq p_{(n)}$. Over all joint distributions with these marginals,*

$$\max \Pr \left(\sum_i X_i \geq k \right) = \min \left(1, \min_{0 \leq j < k} \frac{1}{k-j} \sum_{i>j} p_{(i)} \right),$$

and the maximum is attained.

Proof of validity. Fix $j < k$. On $\{\sum_i X_i \geq k\}$ the j variables with the largest marginals contribute at most j , so the other $n-j$ sum to at least $k-j$; hence $\mathbf{1}_{\{\sum_i X_i \geq k\}} \leq \frac{1}{k-j} \sum_{i>j} X_{(i)}$ pointwise. Taking expectations bounds the probability by $\frac{1}{k-j} \sum_{i>j} p_{(i)}$ for every j , and trivially by one. Attainment is the classical extremal-coupling construction for Fréchet-type bounds [8]; we verified the closed form against the linear program over all 2^n outcome atoms on random instances to 10^{-9} . $\square$

The bound is non-decreasing in every p_i , which is why the worst case of the certificate sits at the corner of the uncertainty set used in the main text.